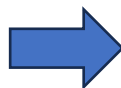


이슈 : api 키 노출로 제미나이 비용 폭탄 발생

사건 개요 : 기존 API 키에 제미나이 권한이 자동 활성화되어 무차별 호출당함*

1. 즉각 대응

- 해당 API 키 즉시 삭제 또는 비활성화 (Revocation)
- 구글 클라우드 콘솔(GCP)에서 노출된 키를 즉시 삭제하여 추가 호출을 차단합니다.
- 관련 결제 계정(Billing Account) 일시 중지
- 추가적인 인프라 악용 가능성을 차단하기 위해 결제 연동을 일시적으로 분리합니다.
- 구글 클라우드 서포트 팀 '비용 감면(Billing Amnesty)' 요청
- 사고 인지 즉시 공식 티켓을 오픈하여 해킹/실수 노출임을 소명하고 청구 비용 감면 조율을 진행합니다.



2. 사후 분석

[사후 분석] 유출 경로 및 피해 규모 파악 (Analysis)

API 호출 로그 및 인보이스 분석

어떤 IP와 리전에서 제미나이 API(예: Gemini Pro/Flash 등)를 무차별 호출했는지, 정확한 누적 피해 금액을 파악합니다.

유출 소스 트래킹

GitHub 퍼블릭 리포지토리, 클라이언트 사이드 코드(하드코딩), 혹은 빌드 아티팩트 등 정확한 키 유출 경로를 추적하여 차단합니다.

비용방어책

3. [비용 방어책] 구글 클라우드 기반 과금 가드레일 구축 (Financial Guardrails)

제미나이 API 선불 결제(Prepaid Billing) 도입

사후 종량제(Postpaid) 대신 미리 크레딧을 구매하여 사용하는 선불 방식으로 전환하여, 해킹을 당하더라도 충전된 금액 이상으로 비용이 폭탄 청구되는 리스크를 원천 차단합니다.

프로젝트/결제 계정별 하드 한도(Hard Budget Limit) 설정

비용이 설정한 임계치(예: 월 250달러 또는 사내 기준 예산)에 도달하면 즉시 API 호출이 자동 차단(Denial of Service) 되도록 설정합니다.

실시간 예산 알림(Billing Alerts) 연동

예산의 50%, 80%, 100% 도달 시 담당 팀의 슬랙(Slack) 및 이메일로 즉각 경고가 발송되도록 자동화합니다.

4. [보안 고도화] API 권한 및 자격 증명 최소화 (Governance)

API 키 사용 범위(API Restrictions) 철저히 제한

키 생성 시 모든 API를 호출할 수 있게 두지 말고, 해당 프로젝트에 필요한 특정 API만 호출할 수 있도록 범위를 엄격하게 제한합니다. (※ 이번 사건처럼 기존 키에 제미나이 권한이 자동으로 부여되어 악용되는 것을 방지)

접근 리스트(Application Restrictions) 제한

웹사이트(HTTP 리퍼러), 특정 서버 IP 대역에서만 해당 API 키를 인식하도록 제한을 걸어 둡니다.

시크릿 관리자(Secrets Manager) 활용

소스 코드 내에 API 키를 절대 하드코딩하지 않고, AWS Secrets Manager나 GCP Secret Manager를 통해 환경 변수로 동적 로드합니다.